

HiveForce Labs

THREAT ADVISORY

 **VULNERABILITY REPORT**

**VMware addresses Security Flaws in
vRealize Log Insight**

Date of Publication

January 25, 2023

Admiralty Code

A1

TA Number

TA2023044

Summary

First Seen: January 24, 2023

Affected Products: VMware vRealize Log Insight

Impact: Vulnerable to attacks involving remote code execution.

⚙ CVE

CVE	NAME	PATCH
CVE-2022-31706	VMware vRealize Log Insight Directory Traversal Vulnerability	✓
CVE-2022-31704	VMware vRealize Log Insight broken access control Vulnerability	✓
CVE-2022-31710	VMware vRealize Log Insight contains a Deserialization Vulnerability	✓
CVE-2022-31711	VMware vRealize Log Insight contains an Information Disclosure Vulnerability	✓

Vulnerability Details

#1

VMware is addressing security flaws in vRealize Log Insight, also known as Aria Operations for Logs, that could potentially lead to remote code execution attacks. Unauthenticated malicious actors can insert files into the operating systems of compromised products. The directory traversal and broken access control flaws, identified as CVE-2022-31706 and CVE-2022-31704, can be exploited by a threat actor to accomplish remote code execution, regardless of the attack strategy.

#2

An unauthenticated attacker might use a third vulnerability, a deserialization weakness (CVE-2022-31710), to cause a denial-of-service (DoS) condition. Finally, vRealize Log Insight has been discovered to be vulnerable to an information disclosure problem (CVE-2022-31711) that could provide unauthenticated access to sensitive session and application data.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-31706	VMware vRealize Log Insight version: 8.x & VMware Cloud Foundation (VMware vRealize Log Insight) version: 4.x, 3.x	cpe:2.3:a:vmware:vrealize_log_insight:-:*:*:*:*:*	CWE-22
CVE-2022-31704			CWE-284
CVE-2022-31710		cpe:2.3:a:vmware:vmware_cloud_foundation:-:*:*:*:*:*	CWE-20
CVE-2022-31711			CWE-200

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Details' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence
<u>TA0008</u> Lateral Movement	<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1543</u> Create or Modify System Process
<u>T1210</u> Exploitation of Remote Services	<u>T1190</u> Exploit Public-Facing Application	<u>T1078</u> Valid Accounts	<u>T1098</u> Account Manipulation

Patch Links

<https://www.vmware.com/security/advisories/VMSA-2023-0001.html>

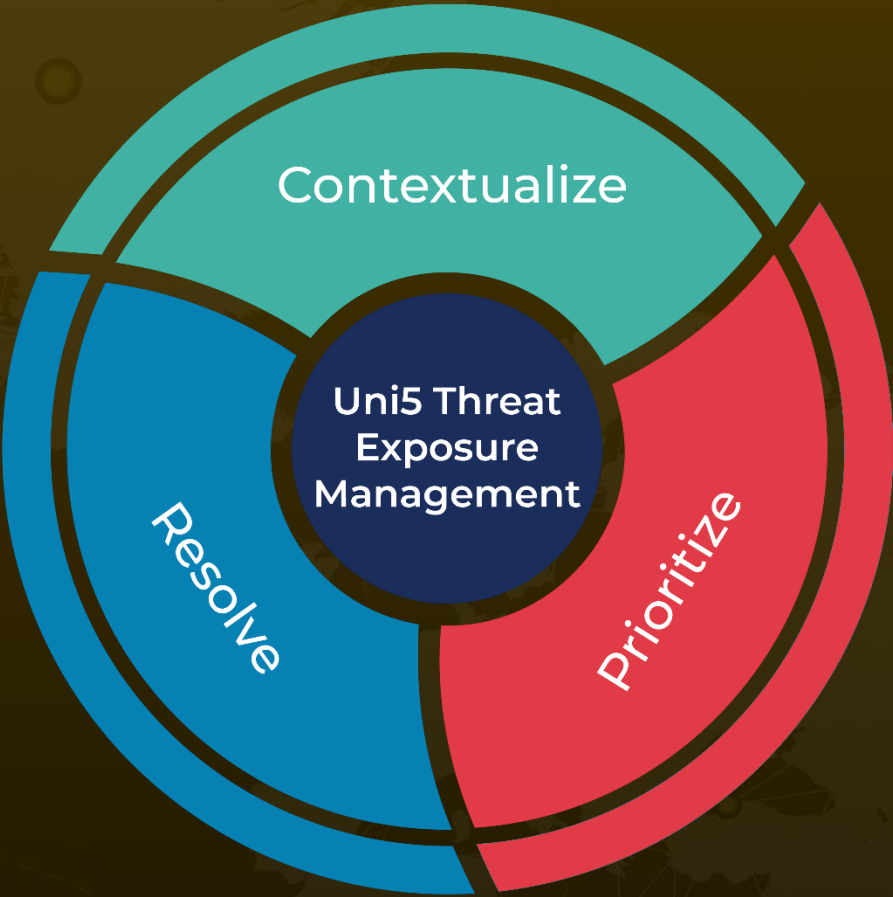
References

<https://www.securityweek.com/vmware-plugs-critical-code-execution-flaws/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

January 25, 2023 • 1:55 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com